

## GUÍA METODOLÓGICA DETALLADA

### Encuesta sobre Madurez en Gestión de Vulnerabilidades CVSS 4.0 • España 2025–2026

*"La metodología es la honestidad de la ciencia. Una investigación sin metodología es una opinión bien vestida."*

## 1. FUNDAMENTOS EPISTEMOLÓGICOS Y DISEÑO DE INVESTIGACIÓN

### 1.1 Paradigma de Investigación

La presente encuesta se enmarca en un paradigma **mixto** que combina:

- Enfoque cuantitativo (Secciones 1–9 con escalas Likert y opciones cerradas): permite comparación estadística entre organizaciones, sectores y CCAA, así como el cálculo del Índice de Madurez Global (IGM).
- Enfoque cualitativo (Preguntas abiertas P3.5, P6.5, P10.5, P10.6): captura matices, experiencias contextuales y propuestas de mejora no codificables en opciones cerradas.

### 1.2 Tipo de Estudio

- Diseño: Transversal descriptivo con componente analítico
- Alcance temporal: Instantánea del estado de madurez (abril 2026), con posibilidad de réplica anual para análisis longitudinal
- Unidad de análisis: La organización (no el individuo), aunque el informante clave sea una persona con responsabilidad directiva en seguridad

### 1.3 Marco Conceptual

El instrumento se fundamenta en tres pilares teórico-normativos:

1. CVSS v4.0 Specification Document y Consumer Implementation Guide (FIRST, 2023–2026): fuente primaria de la taxonomía de métricas y su función en el ciclo de vida de gestión de vulnerabilidades.
2. Marco normativo español y europeo: ENS (RD 311/2022), NIS2 (Directiva UE 2022/2555), DORA (Reglamento UE 2022/2554), CRA (Reglamento UE 2024/2847), EUVD (ENISA, 2025).
3. Modelos de madurez en gestión de vulnerabilidades: CMMI, OWASP SAMM, NIST SSDF, modelos académicos revisados por pares.

## 2. DISEÑO MUESTRAL

### 2.1 Población Objetivo

**Universo:** Todas las organizaciones con presencia operativa en España que gestionen activos de información TI/OT/IoT, incluyendo:

- Administración Pública (AGE, CCAA, entidades locales, universidades)
- Sector privado regulado (financiero, energético, sanitario, telecomunicaciones, transporte)

- Sector privado no regulado con activos críticos
- Proveedores de servicios gestionados de seguridad (MSSP)

**Informante clave:** Responsable de Seguridad de la Información (CISO/RSSI/Responsable ENS) o equivalente con responsabilidad directa en gestión de vulnerabilidades.

## 2.2 Marco Muestral

| Segmento                             | Criterio de inclusión               | Tamaño mínimo recomendado |
|--------------------------------------|-------------------------------------|---------------------------|
| AGE y organismos dependientes        | Obligatoriedad ENS + CCN-CERT       | 50                        |
| Comunidades Autónomas (17+2)         | Gobierno autonómico + consejería TI | 60 (3-4 por CCAA)         |
| Entidades Locales                    | Ayuntamientos >50.000 hab.          | 80                        |
| Hospitales y red sanitaria pública   | ENS + NIS2 entidad esencial         | 60                        |
| Universidades públicas               | ENS obligatorio                     | 40                        |
| Sector financiero (DORA)             | Entidades sujetas a DORA            | 50                        |
| Sector energético (NIS2)             | Operadores esenciales               | 30                        |
| Sector telecomunicaciones            | Operadores esenciales NIS2          | 25                        |
| PYMES y empresas privadas general    | NIS2 entidades importantes          | 100                       |
| MSSP y consultoras de ciberseguridad | Perspectiva experta                 | 30                        |
| <b>TOTAL MÍNIMO</b>                  |                                     | <b>525</b>                |

## 2.3 Técnica de Muestreo

Se recomienda **muestreo estratificado proporcional** con afijación óptima (mayor representación en estratos con mayor varianza esperada: entidades locales y PYMES, por mayor heterogeneidad de madurez).

Para el sector público: **censo** de las entidades de mayor tamaño (>5.000 empleados) + muestra aleatoria simple del resto.

## 2.4 Tamaño Muestral y Error

Con ( $n = 525$ ) y asumiendo varianza máxima ( $(p = q = 0.5)$ ):

$$[e = z_{\alpha/2} \cdot \sqrt{\frac{p \cdot q}{n}}] = 1.96 \cdot \sqrt{\frac{0.25}{525}} \approx \pm 4.3\%$$

Con nivel de confianza del 95%. Para análisis por CCAA se recomienda mínimo de 30 casos por comunidad.

### 3. INSTRUMENTO: ESTRUCTURA Y DECISIONES DE DISEÑO

#### 3.1 Justificación de las Escalas

**Escala Likert 1-5:** Utilizada en preguntas de actitud/percepción y valoración de madurez. Se ha optado por escala impar (con punto medio neutral) para no forzar posicionamiento en preguntas donde la ambivalencia es legítima.

**Escala de madurez 1-5 (secciones 4.6, 5.6, 6.4, 9.6):** Inspirada en el Capability Maturity Model Integration (CMMI), con descriptores:

- **1 — Inexistente:** Sin proceso reconocible
- **2 — Inicial:** Ad hoc, dependiente de personas clave
- **3 — Definido:** Documentado y repetible
- **4 — Gestionado:** Medido y controlado con KPIs
- **5 — Optimizado:** Mejora continua y benchmarking activo

**Escala 1-10 (Sección 11):** Para percepción global, permite mayor discriminación y facilita comparación con benchmarks sectoriales internacionales.

#### 3.2 Estructura de Flujo y Bifurcaciones

El cuestionario incluye las siguientes bifurcaciones condicionales (recomendadas en implementación digital):

P1.7 [No sujeto ENS] → saltar P1.8  
P2.3 [No CVSS] → saltar Secciones 3-6 → pasar a P7.1  
P2.4 [ya usa v4] → saltar P2.4 (no aplica)  
P3.4 [no operan OT] → saltar al final de P3.4  
P6.2 [no infraestructuras con impacto físico] → saltar P6.3  
P7.3 [no sujeto DORA] → marcar N/A

#### 3.3 Tiempo de Respuesta por Sección

| Sección                        | Preguntas | Tiempo estimado |
|--------------------------------|-----------|-----------------|
| 1. Perfil                      | 8         | 3-4 min         |
| 2. Conocimiento CVSS 4.0       | 7         | 5-6 min         |
| 3. Métricas Base               | 5         | 4-5 min         |
| 4. Métricas Threat             | 6         | 4-5 min         |
| 5. Métricas Environmental      | 6         | 5-6 min         |
| 6. Métricas Supplemental       | 5         | 4-5 min         |
| 7. Marco normativo             | 6         | 4-5 min         |
| 8. Infraestructura tecnológica | 6         | 4-5 min         |
| 9. Gobierno y cultura          | 6         | 4-5 min         |
| 10. Perspectiva estratégica    | 6         | 6-8 min         |
| 11. IGM                        | 3         | 2-3 min         |
| TOTAL                          | 64        | 45-57 min       |

## 4. PROCESO DE RECOGIDA DE DATOS

### 4.1 Modalidades de Aplicación

| Modalidad                                                | Ventajas                                    | Limitaciones                             | Recomendación                                  |
|----------------------------------------------------------|---------------------------------------------|------------------------------------------|------------------------------------------------|
| Online<br>(LimeSurvey/Google Forms/Qualtrics)            | Escalabilidad, costes bajos, automatización | Menor tasa de respuesta sin incentivos   | Primaria para sector privado y PYMES           |
| Entrevista estructurada<br>(presencial/videoconferencia) | Mayor profundidad, menor abandono           | Costes elevados, sesgo del entrevistador | Preferente para AGE, CCAA grandes y hospitales |
| Panel de expertos<br>(Delphi complementario)             | Validación de hallazgos con expertos        | No representativo estadísticamente       | Complementario para preguntas abiertas         |

### 4.2 Periodo de Recogida Recomendado

- Pretest/Piloto: 2 semanas con 20–30 casos de distintos segmentos
- Campo principal: 8–10 semanas
- Recordatorios: Semanas 3 y 6 del periodo de campo
- Cierre: Verificación y limpieza de datos: 2 semanas adicionales

### 4.3 Consideraciones Éticas y RGPD

- Consentimiento informado explícito antes de iniciar el cuestionario
- Tratamiento anonimizado: ninguna respuesta individual identificable en informes
- Datos almacenados en servidores dentro de la UE
- Responsable del tratamiento: entidad investigadora (citar)
- Plazo de conservación: máximo 5 años para análisis longitudinal
- Base legal: interés legítimo en investigación científica (Art. 6.1.f RGPD)

## 5. CODIFICACIÓN Y ANÁLISIS DE DATOS

### 5.1 Libro de Códigos

**Variables sociodemográficas (Sección 1):** Nominales/ordinales, análisis descriptivo y como variables de agrupación.

**Variables de conocimiento (Sección 2):** Ordinales, análisis de frecuencias + prueba Chi-cuadrado para independencia con variables de perfil.

**Escala Likert (Secciones 3–9):** Análisis factorial exploratorio (AFE) para validar constructos latentes de madurez. Prueba de Bartlett y KMO  $\geq 0.7$  como criterio de adecuación muestral.

**Índice de Madurez Global (IGM):** Promedio ponderado de las escalas 1–5 de las secciones 4.6, 5.6, 6.4, 7.6 y 9.6. Ver Plantilla Excel (documento e).

## 5.2 Análisis Estadísticos Recomendados

| Objetivo                     | Técnica                           | Variables                                            |
|------------------------------|-----------------------------------|------------------------------------------------------|
| Perfil de madurez por sector | ANOVA + Scheffé post-hoc          | IGM × tipo organización                              |
| Diferencias por tamaño       | Kruskal-Wallis                    | IGM × número empleados                               |
| Diferencias por CCAA         | ANOVA factorial                   | IGM × comunidad autónoma                             |
| Predictores de madurez       | Regresión múltiple ordinal        | IGM ~ CMDB + Threat intel + formación + herramientas |
| Análisis de conglomerados    | K-means / hierarchical clustering | Perfiles de madurez                                  |
| Análisis de texto libre      | NLP / análisis de contenido       | P3.5, P6.5, P10.5, P10.6                             |

## 5.3 Tratamiento de Respuestas Ausentes

- Missing completamente aleatorio (MCAR): Imputación por media de la escala
- Missing sistemático (MAR): Imputación múltiple con variables correlacionadas
- Preguntas N/A legítimas: Excluidas del análisis de la dimensión específica, no del IGM general
- Umbral de exclusión: Cuestionarios con más del 30% de ítems sin respuesta

# 6. VALIDEZ Y FIABILIDAD DEL INSTRUMENTO

## 6.1 Validez de Contenido

El instrumento ha sido diseñado mediante revisión sistemática de:

- Documentación oficial CVSS 4.0 (FIRST, 2023–2026)
- Consumer Implementation Guide (FIRST, enero 2026)
- Informe ENISA Threat Landscape 2025
- Marco normativo ENS, NIS2, DORA, CRA
- Literatura académica sobre modelos de madurez en ciberseguridad

**Recomendación:** Validación por panel de expertos (mínimo 5 expertos con >10 años de experiencia en gestión de vulnerabilidades) mediante índice de validez de contenido (IVC  $\geq 0.80$  por ítem).

## 6.2 Validez de Constructo

- Análisis factorial exploratorio (AFE): Verificar que los ítems de cada sección cargan en el factor esperado (madurez en métricas Base, Threat, Environmental, Supplemental, Gobierno)
- Validez convergente: Correlación entre IGM autopercebido (P11.1) y IGM calculado  $\geq 0.60$
- Validez discriminante: Los factores de distintas secciones deben ser estadísticamente distintos

## 6.3 Fiabilidad (Consistencia Interna)

- Alfa de Cronbach para cada escala de madurez (Secciones 4.6, 5.6, 6.4, 7.6, 9.6): objetivo  $\alpha \geq 0.70$
- Omega de McDonald como alternativa más robusta a alfa
- Test-retest (recomendado): Reaplicación a submuestra de 30–40 casos tras 4 semanas

## 7. LIMITACIONES CONOCIDAS Y MITIGACIÓN

| Limitación                          | Descripción                                        | Estrategia de mitigación                                                                         |
|-------------------------------------|----------------------------------------------------|--------------------------------------------------------------------------------------------------|
| <b>Sesgo de deseabilidad social</b> | Tendencia a declarar mayor madurez de la real      | Preguntas de comportamiento concreto ("¿qué hace?") > preguntas de opinión ("¿debería hacerse?") |
| <b>Sesgo de respuesta única</b>     | Un solo informante por organización                | Triangulación con datos secundarios (auditorías ENS, informes CCN)                               |
| <b>Infrarepresentación de PYMES</b> | Menor tasa de respuesta en organizaciones pequeñas | Sobremuestreo + incentivos específicos (informe comparativo sectorial gratuito)                  |
| <b>Varianza del método común</b>    | Toda la info proviene de la misma fuente           | Harman's single factor test; separación temporal de bloques de preguntas                         |
| <b>Evolución rápida del entorno</b> | CVSS 4.0 y normativa cambian rápido                | Fecha de recogida claramente documentada; revisión anual                                         |

## 8. EQUIPO DE INVESTIGACIÓN Y CRONOGRAMA

### 8.1 Perfil del Equipo Recomendado

- 1 Investigador Principal con experiencia en gestión de vulnerabilidades y ciberseguridad (CISM/CISSP/OSCP)
- 1 Metodólogo/estadístico especializado en encuestas organizacionales
- 2 Investigadores de campo para entrevistas estructuradas (sector público)
- 1 Analista de datos y visualización
- 1 Revisor de contenido normativo (ENS, NIS2, CRA)

### 8.2 Cronograma de Proyecto

| Fase          | Actividad                                          | Duración               |
|---------------|----------------------------------------------------|------------------------|
| <b>Fase 1</b> | Diseño final del instrumento + validación expertos | 4 semanas              |
| <b>Fase 2</b> | Piloto + ajustes + programación plataforma online  | 3 semanas              |
| <b>Fase 3</b> | Recogida de datos principal                        | 10 semanas             |
| <b>Fase 4</b> | Limpieza, codificación y análisis                  | 4 semanas              |
| <b>Fase 5</b> | Redacción del informe + revisión                   | 4 semanas              |
| <b>Fase 6</b> | Presentación de resultados                         | 2 semanas              |
| <b>TOTAL</b>  |                                                    | ~27 semanas (~7 meses) |

## **Kit de Encuesta CVSS 4.0 · España 2025–2026 · Guía Metodológica**

### **Versión 1.0 · Abril 2026**